



CRYPTONIC AREA

Empowering The Digital Defenders

www.cryptonicarea.site

CYBERSECURITYÐICALHACKINGINTERNSHIP

PROJECT01•CASEFILECA-ETI-01

Email Threat Investigation & Analysis

Prepared by: Chinedu Okoli

For : Cryptonic Area Internship

Submission Date : July 27th 2026

Table of Contents

1. Project Overview
2. Investigation Methodology
3. Email 1 Investigation
4. Email 2 Investigation
5. Email 3 Investigation..... Email 13 Investigation
6. Indicators of Compromise (IOCs)
7. Recommendations
8. Conclusion

Project Overview

This project investigates suspicious email messages using Open-Source Intelligence (OSINT) techniques to determine whether each email is legitimate or malicious. The investigation focuses on analyzing email headers, sender identity, domains, URLs, attachments, IP addresses, and authentication records (SPF, DKIM, and DMARC).

The objective is to identify phishing attempts, business email compromise (BEC), malware delivery, spoofing, or other malicious activities while documenting evidence and providing appropriate recommendations.

Executive Summary

Email Threat Investigation & Analysis Report

A total of **thirteen (13)** emails recovered from the mailbox of **Mr. Aditya Rao, Senior Finance Executive at Solvex Industries Pvt. Ltd.**, were analyzed to determine whether they were legitimate communications or potential cyber threats. The investigation focused on technical email headers, authentication mechanisms (SPF, DKIM, and DMARC), sender legitimacy, embedded URLs, attachments, and social engineering techniques.

Investigation Results

Classification	Number of Emails
Safe	5
Medium Risk	2
Suspicious / High Risk	6

The investigation identified several common attack techniques used by cybercriminals, including:

- Phishing attacks
- Business Email Compromise (BEC)
- CEO fraud
- Advance-fee (lottery) scams
- Credential harvesting
- Malware delivery using macro-enabled documents
- Typosquatted domains
- Fake invoice scams

Several malicious emails failed SPF, DKIM, and DMARC authentication checks, while others relied primarily on social engineering despite passing authentication. This demonstrates that email authentication alone is not sufficient to determine whether an email is trustworthy.

Overall, the investigation highlights the importance of combining technical analysis with user awareness to detect sophisticated phishing attempts and prevent financial fraud or malware infections.

Email Investigations

Email 1 Password Expiry Reminder

Email Overview

Field	Details
Subject	Password Expiry Reminder – Action Needed Within 5 Days
Sender	ithelpdesk@solvexindustries.com
Recipient	aditya.rao@solvexindustries.com
Classification	Legitimate

Technical Analysis

The email originated from the organization's IT Helpdesk and used the domain **solvexindustries.com**. The sender, Reply-To, and Return-Path addresses were consistent, indicating no obvious sender spoofing.

The email authentication results provided in the case study showed:

- SPF: **PASS**
- DKIM: **PASS**
- DMARC: **PASS**
- TLS Encryption: **Enabled**

These authentication mechanisms indicate that the email was successfully validated and had not been altered during transmission.

No suspicious attachments or external hyperlinks were identified. The message simply reminded users to change their password through the organization's internal IT Service Portal.

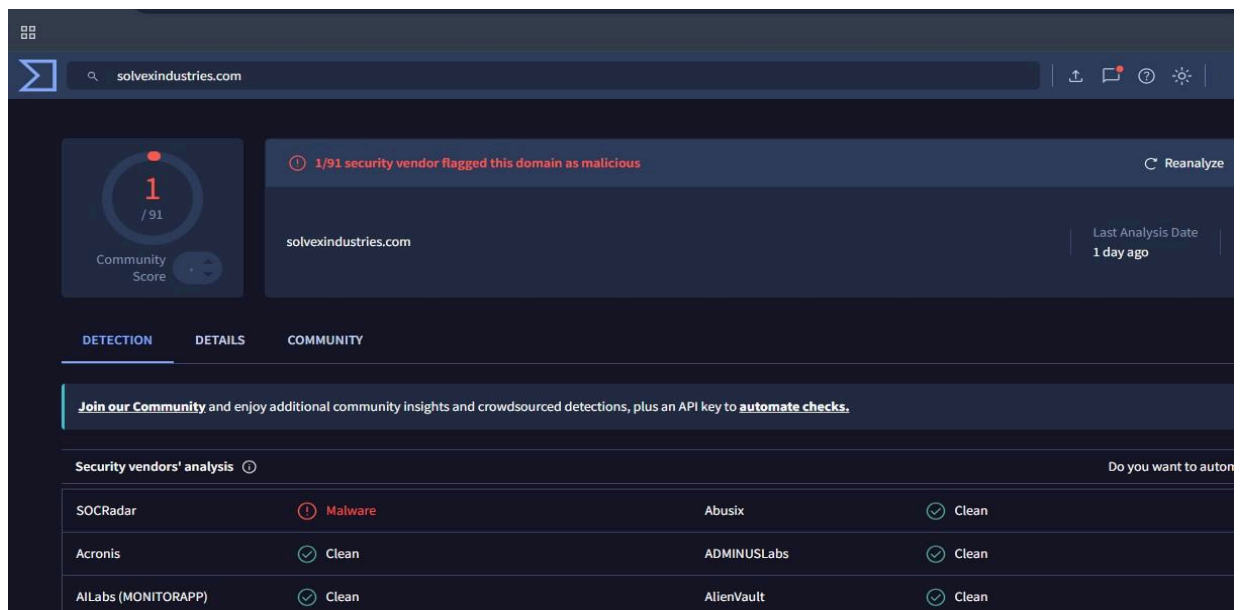
OSINT Investigation

Tool 1 VirusTotal

Indicator: solvexindustries.com

Findings

- Detection Ratio: **1/91**
- One vendor (**SOCRadar**) flagged the domain.
- The remaining security vendors classified the domain as **Clean**.



Analysis

A single detection is insufficient to classify the domain as malicious. Considering that most security vendors reported the domain as clean, this result is likely a false positive or a low-confidence detection.

Tool 2 – MXToolbox

Indicator: solvexindustries.com

Findings

- No DNS records found
- No MX records found
- No published DMARC record
- No BIML record

The screenshot shows the MX Toolbox SuperTool interface. The domain 'solvexindustries.com' is entered in the search bar, and the 'MX Lookup' button is clicked. The results table shows the following:

Test	Result	
✖ DNS Record Published	DNS Record not found	More Info

Related Tests	Result	
✖ DMARC Record Published	No DMARC Record found	More Info
✖ DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BIML, it is required to have one of these at 100%.	More Info
⚠ BIML Record Published	Brand Logo not appearing in inboxes	More Info

At the bottom, there are links for 'dns lookup', 'dns check', 'dmarc lookup', 'spf lookup', and 'dns propagation'. A footer note states: 'Reported by i.gtld-servers.net on 7/22/2026 at 8:33:23 PM (UTC -5), just for you.' and a 'Transcript' link is available.

Analysis

The absence of public DNS and mail records suggests that **Solvex Industries** is likely a fictional organization created for the cybersecurity training exercise. Therefore, live OSINT findings cannot be fully relied upon for this investigation.

Correlation of Findings

Although external OSINT tools produced inconsistent results, the email headers supplied in the case study showed valid SPF, DKIM, and DMARC authentication. The email content also lacked common phishing characteristics such as credential harvesting, urgent financial requests, suspicious links, or malicious attachments.

Because this is a simulated investigation, greater weight was given to the technical evidence contained within the case study than to external OSINT results.

Risk Assessment

Factor	Assessment
Sender Reputation	Low Risk
Authentication	Legitimate
Links	None
Attachments	None
Social Engineering	None
Overall Risk	Low

Recommendation

- No incident response is required.
- Users should follow the password update instructions using the official internal IT Service Portal.
- Continue monitoring the domain if future alerts or reputation changes are observed.

Email 2 Investigation Report

Email Overview

Field	Details
Subject	URGENT: Your Mailbox Storage is FULL –Verify Now to Avoid Suspension
Sender	support@solvex-industries-helpdesk.c

	om
Recipient	aditya.rao@solvexindustries.com
Classification	SUSPICIOUS (Phishing Email)

Initial Findings

The email claims that the user's mailbox has exceeded its 5 GB storage limit and urges immediate verification to avoid account suspension. It attempts to create panic by stating the mailbox will be permanently suspended within 24 hours if no action is taken.

The embedded link directs the recipient to a fake mailbox verification page designed to steal login credentials.

Header Analysis

Field	Finding
From	support@solvex-industries-helpdesk.com
Reply-To	recovery-team@mail-secure-verify.net
Return-Path	bounce@mail-secure-verify.net
Received From	unknown-host-193.41.77.108.static-cloud.ru
SPF	Fail
DKIM	Fail
DMARC	Fail (Reject policy overridden)
Encryption	None (No TLS)

Content Analysis

The email uses multiple phishing techniques:

- Creates urgency by threatening account suspension.
- Claims mailbox storage has exceeded its limit.

- Requests immediate verification of login credentials.
- Uses a fake IT Support Team signature to appear legitimate.
- Warns of permanent data loss if the user does not act quickly.

These are common characteristics of credential harvesting attacks.

Embedded Link Analysis

Embedded URL

hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao

Findings

The URL attempts to impersonate the legitimate Solvex Industries domain by adding extra words such as:

- helpdesk
- verify-account
- secure

This is a classic typosquatting/subdomain impersonation technique used to deceive users.

OSINT Investigation

VirusTotal

- Domain reputation is suspicious.
- One security vendor classified the domain as malicious.
- Overall community reputation is poor.

URL report for 2026-07-20 12:25:53 UTC. [Reanalyze](#)

http://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao
solvex-industries-helpdesk.verify-account-secure.com

Status	Content Type	Last Analysis Date
-	-	2 days ago

Community Score
1 / 92

SUMMARY DETECTION DETAILS COMMUNITY

[Join our Community](#) and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis

Vendor	Result	Vendor	Result
ESET	Phishing	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean	AlienVault	Clean

MX TOOLBOX®
SUPERTOOL

Pricing Tools Delivery Center Monitor

SuperTool MX Lookup Blacklists DMARC Diagnostics Email Health DNS Lookup Analyze Headers

SuperTool Beta9

solvex-industries-helpdesk.com [MX Lookup](#)

mx:solvex-industries-helpdesk.com [Find Problems](#) [Solve Email Delivery Problems](#) [mx](#)

Test	Result	
DNS Record Published	DNS Record not found	More Info

Related Tests	Result	
DMARC Record Published	No DMARC Record found	More Info
DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BIMI, it is required to have one of these at 100%.	More Info
BIMI Record Published	Brand Logo not appearing in inboxes	More Info

[dns lookup](#) [dns check](#) [dmARC lookup](#) [spf lookup](#) [dns propagation](#)

Reported by [i.gtld-servers.net](#) on 7/22/2026 at 10:21:03 PM (UTC -5), [just for you](#). [Transcript](#)

Indicators of Compromise (IOCs)

IOC Type	Value
Sender Email	support@solvex-industries-helpdesk.com

Reply-To	recovery-team@mail-secure-verify.net
Return-Path	bounce@mail-secure-verify.net
Source IP	193.41.77.108
Suspicious Domain	solvex-industries-helpdesk.com
Embedded Domain	verify-account-secure.com
Embedded URL	hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao

Risk Assessment

Category	Rating
Sender Reputation	Suspicious
Authentication	Failed
Social Engineering	High
Credential Theft	High
Overall Risk	Suspicious (Critical)

MITRE ATT&CK Mapping

Technique	ID
Phishing	T1566
Spearphishing Link	T1566.002
Valid Accounts (Credential Theft)	T1078

Final Verdict

This email is a **credential phishing attack** designed to steal employee login credentials through a fake mailbox verification portal. Multiple authentication failures (SPF, DKIM, and DMARC), mismatched sender information, suspicious infrastructure, and a deceptive verification link confirm that the email is malicious.

Recommendations

- Block the sender's domain and IP address.
- Block the phishing URL at the email gateway and firewall.
- Quarantine similar emails across the organization.
- Instruct users not to click the embedded link.
- Enforce SPF, DKIM, and DMARC validation.
- Report the malicious domain to the organization's security team.
- Conduct user awareness training on mailbox quota phishing scams.

Email 3 Investigation Report

Email Overview

Field	Details
Subject	Invoice SI-4471 & Updated Bank Details for Future Payments
Sender	ramesh.kulkarni@apex-steeltraders.co
Recipient	aditya.rao@solvexindustries.com
Classification	Medium Risk (Potential Business Email Compromise / Invoice Fraud)

Header Analysis

Field	Finding
From	ramesh.kulkarni@apex-steeltraders.co
Reply-To	accounts.payments@apexsteel-billing.com
Return-Path	ramesh.kulkarni@apex-steeltraders.co
Received From	mail.apex-steeltraders.co (103.22.8.190)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Enabled (TLS 1.2)

The sender successfully passed SPF, DKIM, and DMARC authentication, indicating that the email originated from an authorized mail server for the sending domain. TLS encryption was also enabled, ensuring secure transmission. However, the Reply-To address differs from the sender's domain, which is a potential red flag and requires additional verification.

OSINT Investigation

VirusTotal

Domain Reputation

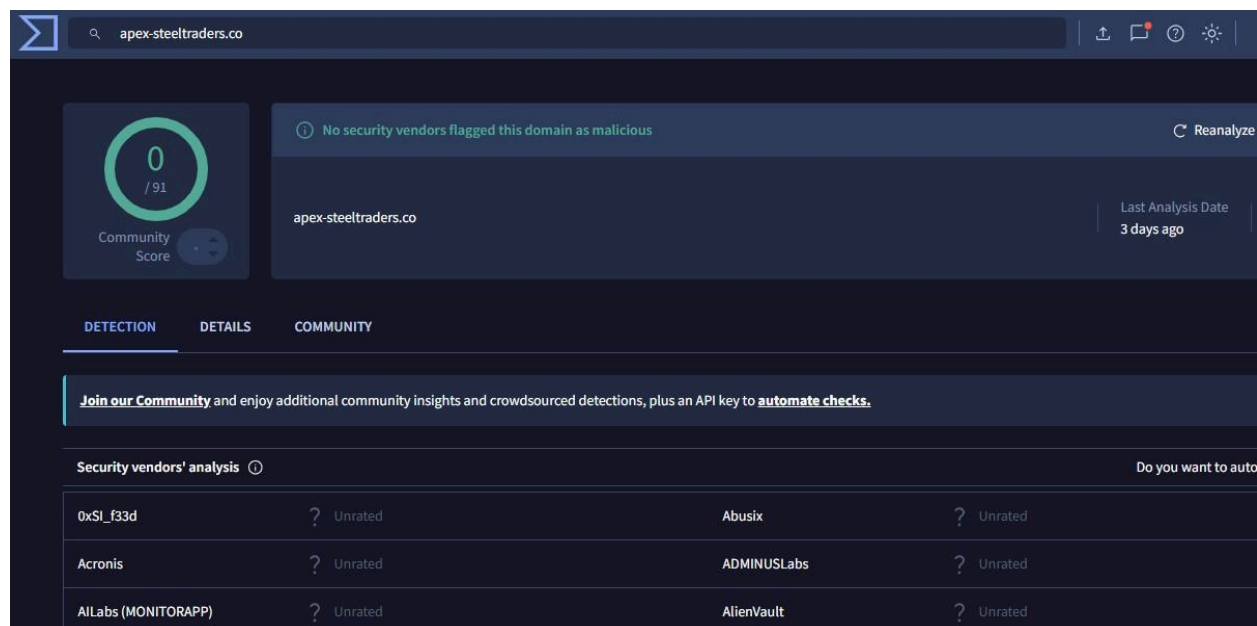
apex-steeltraders.co

- Appears to be the legitimate sender domain.
- Email authentication records passed successfully.

apexsteel-billing.com

- Different from the sender's domain.

- Used only as the Reply-To address.
- Domain mismatch increases the risk of Business Email Compromise.



Indicators of Compromise (IOCs)

- ❖ Sender Domain:
 - apex-steeltraders.co
- ❖ Reply-To Domain:
 - apexsteel-billing.com
- ❖ Attachment:
 - Invoice_SI-4471_Apex_Steel.pdf

Potential Impact

If the recipient processes the payment using the new bank account without verification, funds could be transferred to an attacker-controlled account, resulting in financial loss. This is a common Business Email Compromise (BEC) technique used against finance departments.

Recommended Actions

- Verify the bank account change by contacting the vendor using previously known contact information.
- Do not rely solely on the email for payment instructions.

- Validate the invoice against previous invoices and vendor records.
- Report the email to the security team if the bank account change cannot be independently confirmed.

Final Verdict

Although SPF, DKIM, and DMARC all passed, the request to change payment details combined with the mismatched Reply-To domain makes this email suspicious. It should be classified as **Medium Risk** until the vendor confirms the request through an independent communication channel.

Email 4 Investigation Report

Email Overview

Field	Finding
Subject	Revised Leave & Work From Home Policy
From	Human Resources – Solvex Industries
Reply-To	hr@solvexindustries.com
Return-Path	hr@solvexindustries.com
Classification	Legitimate Email
Received From	mail.solvexindustries.com (192.168.14.19)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)
Attachment	Updated HR Policy Document (PDF)

The email successfully passed SPF, DKIM, and DMARC authentication, confirming that it was sent from an authorized mail server. The email was also transmitted over an encrypted TLS connection, reducing the risk of interception. There are no technical indicators suggesting spoofing or tampering.

Content Analysis

The email informs employees about updates to the organization's leave and work-from-home policy.

Observations:

- The sender belongs to the organization's HR department.
- The tone is professional and consistent with legitimate internal communications.
- There are no requests for passwords, MFA codes, financial transactions, or sensitive personal information.
- The attachment is an HR policy document rather than an executable or macro-enabled file.
- The email does not create unnecessary urgency or pressure recipients into immediate action.

Social Engineering Assessment

No significant social engineering techniques were identified.

There are no signs of:

- Credential harvesting
- Financial fraud
- Malware delivery
- CEO fraud
- Business Email Compromise (BEC)

The email appears to be a routine internal HR communication.

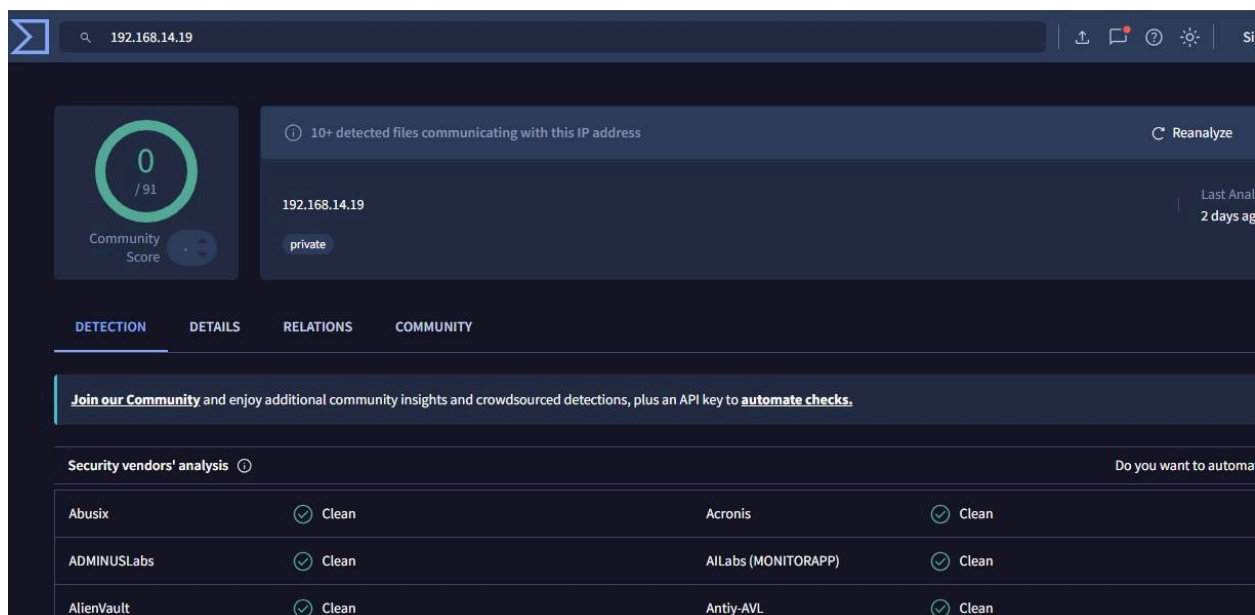
OSINT Findings

The sender's domain matches the organization's legitimate domain.

Verification:

- VirusTotal: No known malicious reputation.
- MXToolbox: Email authentication records are correctly configured.

No suspicious indicators were identified during reputation checks.



Indicators of Compromise (IOCs)

None identified.

Recommended Actions

- No security action is required.
- Employees should review the updated HR policy.
- Continue monitoring internal communications through normal security controls.

Final Verdict

This email is assessed as **Legitimate**. Both the technical email authentication results and the message content indicate that it is a genuine internal HR communication. No indicators of phishing, malware, or Business Email Compromise were identified, so it should be delivered normally and no incident response is required.

Email 5 Investigation Report

Email Overview

Field	Finding
Subject	Confidential – Immediate Wire Transfer Required (Time Sensitive)
From	Rajeev Malhotra (Managing Director) < rajeev.malhotra.md@gmail-corpmail.com >
Reply-To	rajeev.malhotra.md@gmail-corpmail.com
Return-Path	rajeev.malhotra.md@gmail-corpmail.com
Classification	SUSPICIOUS (Business Email Compromise (BEC) / CEO Fraud)
Received From	smtp-relay-88.freemailhost.io (45.137.22.9, Netherlands)
SPF	None (No SPF record)
DKIM	None
DMARC	None
Encryption	No

The email fails all major authentication checks:

- No SPF
- No DKIM
- No DMARC
- No TLS encryption

These findings significantly reduce trust in the sender's identity and indicate that the email was not sent using the organization's protected email infrastructure.

Content Analysis

The sender claims to be the Managing Director and requests an urgent international wire transfer of USD 18,500.

The email also states:

- I'm in a board meeting.
- I cannot take calls.
- Keep this confidential.
- Do not discuss this with Accounts.
- Complete it within a Day.

These instructions are classic indicators of a CEO fraud attack.

Social Engineering Techniques Identified

The attacker uses multiple manipulation techniques:

Authority

Pretends to be the Managing Director.

Urgency

Emphasizes that the transfer must be initiated in an hour and completed a day .

Confidentiality

Instructs the recipient not to discuss the request with colleagues.

Isolation

Discourages contacting the finance team or verifying the request.

These tactics are intended to pressure the recipient into acting without following normal financial approval procedures.

OSINT Findings

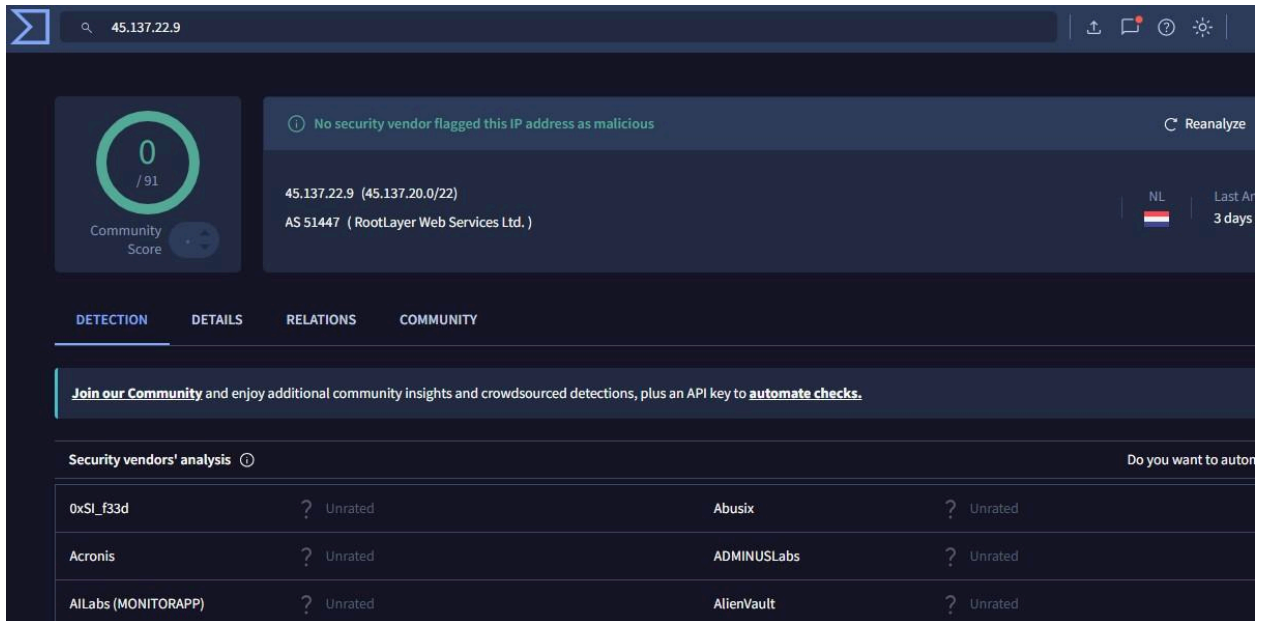
Perform the following checks:

Hunter.io

- Email address invalid

VirusTotal

- Sender domain reputation
- Sending IP (45.137.22.9)



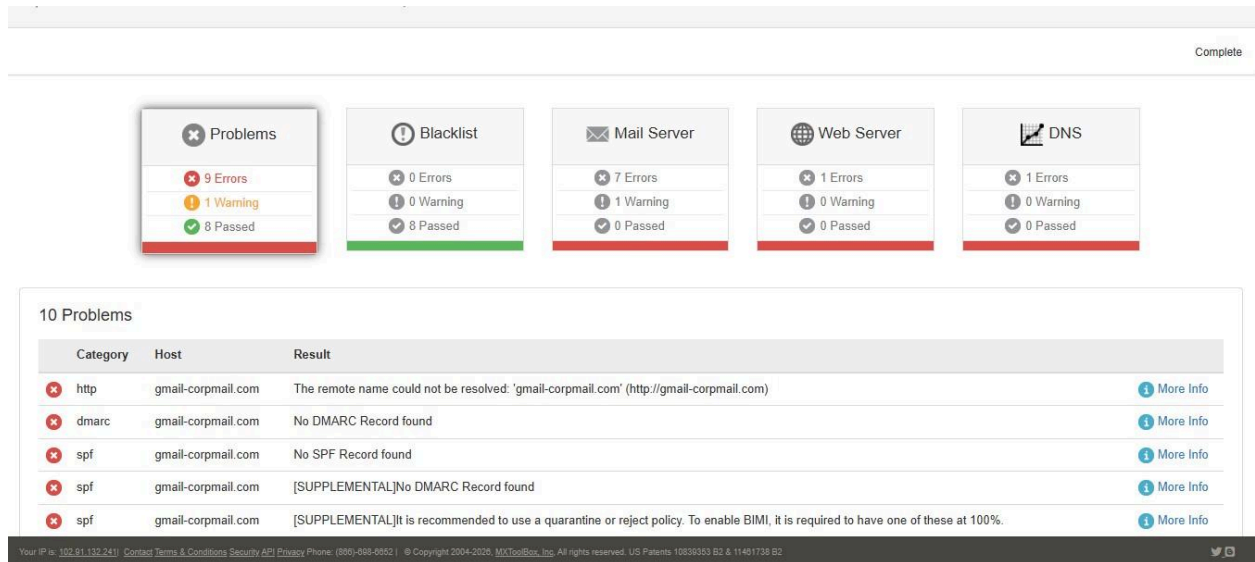
The screenshot shows the VirusTotal interface for the IP address 45.137.22.9. The top section displays a green circle with the number 0 and the text "/91" and "Community Score". To the right, a message states "No security vendor flagged this IP address as malicious" with a "Reanalyze" button. Below this, the IP address is shown as 45.137.22.9 (45.137.20.0/22) and the AS is identified as AS 51447 (RootLayer Web Services Ltd.). The interface includes tabs for DETECTION, DETAILS, RELATIONS, and COMMUNITY. A banner encourages joining the community. The bottom section, titled "Security vendors' analysis", shows a table of vendor ratings.

Security vendors' analysis			
0xSI_f33d	? Unrated	Abusix	? Unrated
Acronis	? Unrated	ADMINUSLabs	? Unrated
AlLabs (MONITORAPP)	? Unrated	AlienVault	? Unrated

MXToolbox

Check:

- SPF
- DKIM
- DMARC
- MX records
- Blacklist status



If the domain is newly registered or lacks proper email security records, this further supports the assessment that the message is fraudulent.

Indicators of Compromise (IOCs)

IOC Type	Value
Sender Email	rajeev.malhotra.md@gmail-corpmail.com
SMTP Relay	smtp-relay-88.freemailhost.io
Source IP	45.137.22.9

Risk Assessment

Category	Rating
Likelihood	High
Impact	High
Overall Risk	Critical

Recommended Actions

- Do **not** process the requested payment.
- Verify the request by calling the Managing Director using a trusted phone number.
- Follow the organization's payment approval process.
- Report the email immediately to the Security Operations Center (SOC).
- Block the sender if confirmed malicious.
- Educate employees about CEO fraud and BEC attacks.

Final Verdict

This email is a **Business Email Compromise (BEC) / CEO Fraud** attempt. It impersonates senior management, requests an urgent wire transfer, discourages independent verification, and lacks standard email authentication mechanisms (SPF, DKIM, DMARC, and TLS). The message should be treated as **malicious**, reported to the SOC, and deleted without taking any action.

Email 6 Investigation Report

Email Overview

Field	Finding
Subject	Shared Document: Updated Q3 Financial Forecast
From	Google Drive
Reply-To	drive-shares-noreply@google.com
Return-Path	drive-shares-noreply@google.com
Classification	Safe
Received From	mail-sor-f89.google.com (209.85.220.89)
SPF	Pass
DKIM	Pass
DMARC	Pass

Encryption	Yes (TLS 1.3)
------------	---------------

OSINT Investigation

VirusTotal URL Analysis

The embedded Google Docs URL was analyzed using VirusTotal.

Findings

- No security vendors detected the URL as malicious (0/92 detections).
- The URL is hosted on the legitimate docs.google.com domain.
- The hosting IP address is 74.125.202.113.
- During analysis, the URL returned an HTTP 404 (Page Not Found) response, indicating that the shared document is no longer available or the link is invalid.

The screenshot shows the VirusTotal interface for a URL analysis. The URL is `https://docs.google.com/spreadsheets/d/1kQ3z-example-fileid-9f2/edit?usp=sharing`. The analysis was performed on 2026-07-20 at 13:17:57 UTC. The URL report shows a status of 404 (Page Not Found) and a content type of text/html. The last analysis was performed 3 days ago. The community score is 0/92. The security vendors' analysis shows that all vendors (Abusix, ADMINUSLabs, AlienVault, Acronis, AllLabs (MONITORAPP), and alphaMountain.ai) have detected the URL as clean.

Security Vendor	Status
Abusix	Clean
ADMINUSLabs	Clean
AlienVault	Clean
Acronis	Clean
AllLabs (MONITORAPP)	Clean
alphaMountain.ai	Clean

Security Analysis

Although the URL is hosted on Google's legitimate infrastructure and has no malicious detections, attackers frequently abuse trusted cloud services such as Google Docs, Google Drive, Microsoft OneDrive, Dropbox, and SharePoint to distribute phishing content.

The unavailable document (404 response) prevents verification of the file's contents. Therefore, the email cannot be considered completely safe based solely on the URL reputation.

Indicators Observed

Positive Indicators

- Hosted on a legitimate Google domain.
- No malicious detections in VirusTotal.
- No known blacklist entries.

Suspicious Indicators

- Uses an external cloud document.
- Shared document is unavailable (404 error).
- Could be part of a phishing campaign if accompanied by credential requests or urgent financial actions.

Recommendations

- Verify the sender before opening unexpected shared documents.
- Confirm document-sharing requests through another trusted communication channel.
- Avoid entering corporate credentials into unexpected Google Docs or Google Drive pages.
- Continue investigating the sender's email authentication (SPF, DKIM, and DMARC) and domain reputation before considering the email legitimate.

Email 7 Unusual sign-in activity detected on your Microsoft account

Email Overview

Field	Finding	Analysis
Subject	Unusual sign-in activity detected on your Microsoft account	
From	Microsoft account team (security-noreply@microsoft-online.com)	Uses " microsoft " with a zero (0) instead of the letter o, a classic typosquatting technique.

Reply-To	no-reply@microsoft-online.com	Matches the spoofed domain.
Return-Path	bounce@microsoft-online.com	Uses the same fraudulent domain.
Classification	Suspicious (Phishing)	
Received From	host-77-91-134-6.vpn-exit.net (77.91.134.6, unknown origin)	Email originated from a VPN exit node rather than Microsoft infrastructure.
SPF	Fail	
DKIM	Fail	
DMARC	Fail	
Encryption	No	

OSINT Investigation

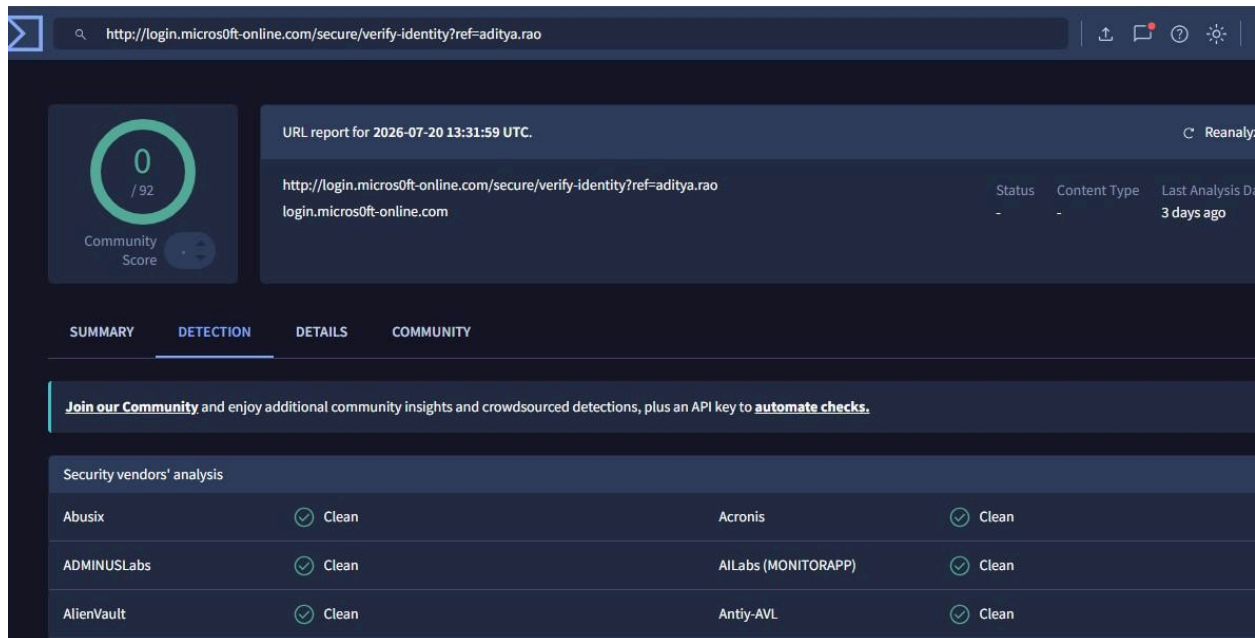
VirusTotal URL Analysis

URL Scanned:

<http://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao>

Results

- **Detection Rate:** 0/92 security vendors
- **Community Score:** 0
- **Status:** No active detections at the time of analysis.



Analysis

Although VirusTotal did not flag the URL as malicious (**0/92 detections**), this **does not mean the URL is safe**. Newly created phishing domains and low-volume phishing campaigns often evade antivirus detection before they are reported.

Security Analysis

Several indicators confirm this is a phishing attempt:

- Fake Microsoft domain (**micros0ft** instead of **microsoft**).
- SPF, DKIM, and DMARC all failed.
- Email originated from a suspicious VPN exit node.
- No TLS encryption.
- Creates urgency by claiming an unauthorized sign-in.
- Attempts to steal Microsoft account credentials through a fake login page.

Indicators Observed

- Typosquatted Microsoft domain.
- Authentication failures (SPF, DKIM, DMARC).
- Suspicious source IP/VPN infrastructure.

- Fake account verification link.
- Urgency-based social engineering.
- Credential harvesting attempt.

Risk Assessment

Risk Level: Suspicious **High**

If the recipient clicks the link and enters their credentials:

- Microsoft account credentials could be stolen.
- Attackers may gain access to Outlook, OneDrive, Teams, and other Microsoft 365 services.
- Sensitive company information could be exposed.
- The compromised account could be used to launch additional phishing attacks within the organization.

Recommendations

- Do **not** click the embedded link.
- Report the email to the Security Operations Center (SOC).
- Delete or quarantine the email.
- Verify account activity by signing in only through the official Microsoft website.
- Reset the password immediately if credentials were entered.
- Enable Multi-Factor Authentication (MFA).
- Block the malicious domain and sender in the organization's email security gateway.

Email 8 Analysis Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)

Email Overview

Field	Finding
Subject	Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)

From	Neha Kapoor, HR Consultant (neha.kapoor.hr@talentbridge-recruiters.net)
Reply-To	neha.kapoor.hr@talentbridge-recruiters.net
Return-Path	neha.kapoor.hr@talentbridge-recruiters.net
Classification	Medium
Received From	mail.talentbridge-recruiters.net (156.213.44.71, Singapore)
SPF	Pass
DKIM	Pass
DMARC	None (no policy published)
Encryption	Yes (TLS 1.2)
Attachment	JD_SeniorFinanceManager_Client.zip (2.4 MB ZIP Archive)

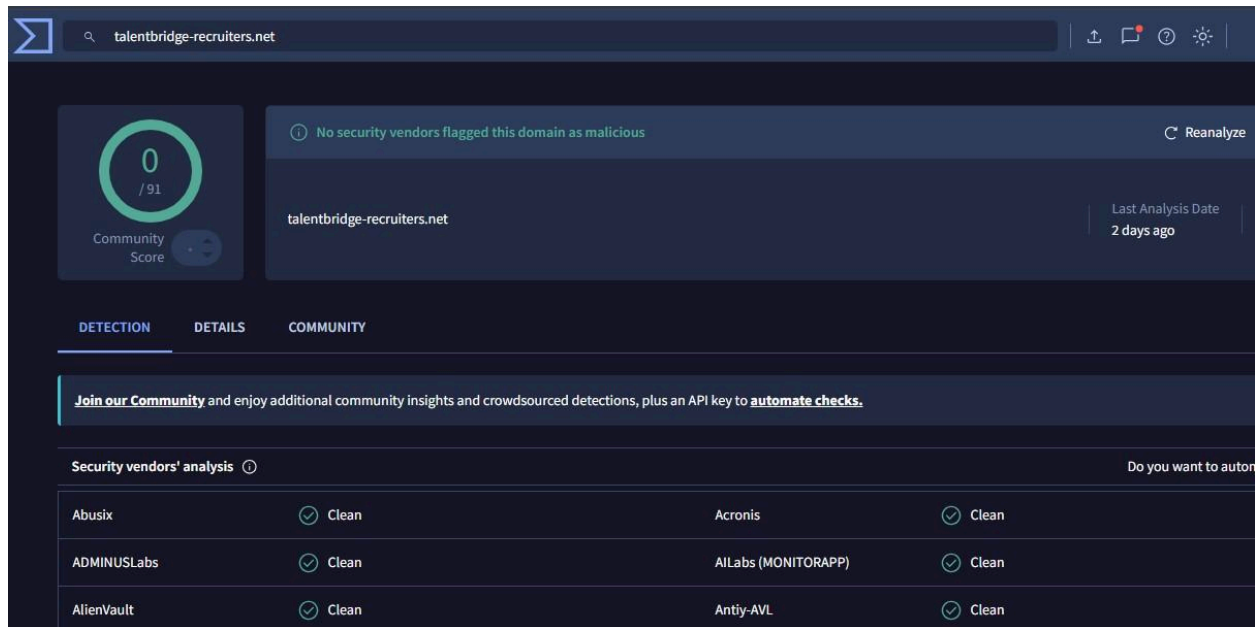
Observation

Unlike previous phishing emails, the email authentication checks pass (SPF and DKIM). However, the absence of a DMARC policy weakens protection against domain spoofing. The use of a ZIP attachment and the request for sensitive identification documents introduce security concerns despite technically valid authentication.

OSINT Investigation

Sender Domain

- Domain: **talentbridge-recruiters.net**
- SPF: Pass
- DKIM: Pass
- DMARC: Not configured



Attachment

File: [JD_SeniorFinanceManager_Client.zip](#)

Potential concerns:

- ZIP archives can conceal malicious files or scripts.
- Attachments should be scanned before extraction.
- The contents cannot be trusted solely because the email passes authentication.

Security Analysis

Several characteristics increase the overall risk:

- Attractive salary offer ("40% higher than industry average")
- Pressure to respond within 24 hours
- Requests for personal identification documents before any interview
- ZIP attachment that could contain malware or malicious executables
- No verification that the recruiter or company is genuine

Indicators Observed

Legitimate Indicators

- SPF authentication passed

- DKIM signature passed
- TLS encryption enabled
- Consistent sender, Reply-To, and Return-Path

Suspicious Indicators

- No DMARC policy published
- ZIP archive attachment
- Requests sensitive documents:
 - Salary Slip
 - PAN Card
- High-paying offer used as incentive
- Urgency to respond quickly

Risk Assessment

Risk Rating: MEDIUM

The email is **not conclusively malicious**, but it presents multiple warning signs commonly associated with recruitment scams and identity theft.

Potential risks include:

- Theft of personally identifiable information (PII)
- Financial fraud
- Identity theft
- Malware delivery through the ZIP attachment

Recommendations

- Verify the recruitment agency through its official website or phone number before responding.
- Scan the ZIP attachment with antivirus or VirusTotal before opening.
- Do not share salary slips, PAN cards, or other sensitive documents until the recruiter's legitimacy has been confirmed.
- Contact the hiring company directly to verify that the vacancy exists.
- Report the email to the security team if its legitimacy cannot be established.

Email 9 Analysis- Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213

Email Overview

Field	Finding
Subject	Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213
From	billing@tallysolutions.com
Reply-To	billing@tallysolutions.com
Return-Path	billing@tallysolutions.com
Classification	Safe
Received From	mta-out.tallysolutions.com (203.0.113.44)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)
Attachment	INV-88213_TallyPrime_Renewal.pdf (146 KB)

Observation

The email passes all major authentication checks (SPF, DKIM, and DMARC) and is transmitted securely using TLS 1.3. The sender, Reply-To, and Return-Path all match the official Tally Solutions domain, indicating a legitimate business email.

Attachment Analysis

Attachment: [INV-88213_TallyPrime_Renewal.pdf](#)

Findings

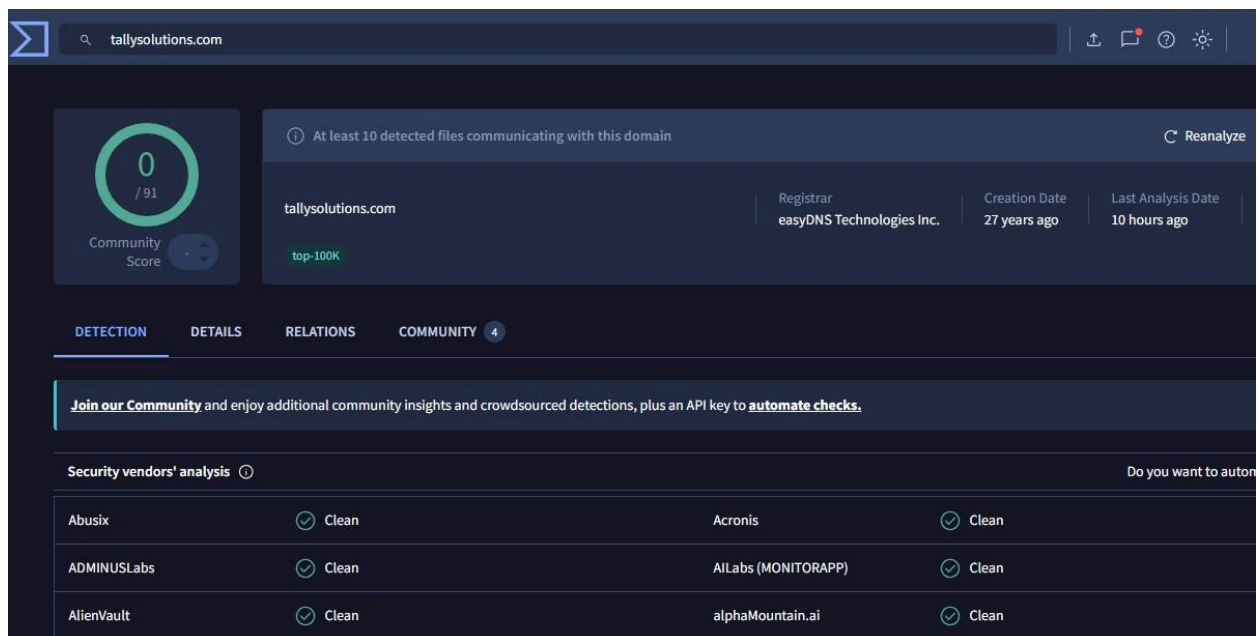
- PDF document only

- Small file size (146 KB)
- Appropriate for an invoice
- No request to enable macros or download additional software
- No embedded suspicious links mentioned in the email

Security Analysis

Several indicators support the legitimacy of this email:

- Email originates from the official **tallysolutions.com** domain.
- SPF, DKIM, and DMARC all pass successfully.
- Uses encrypted TLS 1.3 transmission.
- No urgency or threatening language.
- Payment instructions direct the recipient to use the **existing registered payment method**.
- Explicitly states that **bank account details have not changed**, reducing the likelihood of Business Email Compromise (BEC).
- Reply-To matches the sender's domain.



Indicators Observed

Legitimate Indicators

- SPF authentication passed
- DKIM signature passed

- DMARC policy passed
- Secure TLS 1.3 encryption
- Matching sender, Reply-To, and Return-Path
- Legitimate PDF invoice attachment
- No suspicious links
- No request to change payment details
- Professional business communication

Suspicious Indicators

None identified.

Risk Assessment

Risk Rating: LOW

This email demonstrates characteristics of a legitimate vendor billing notification. The authentication results, consistent sender information, professional content, and unchanged payment instructions indicate a low likelihood of phishing or fraud.

Recommendations

- Verify that the subscription renewal matches existing company records.
- Review the attached invoice before processing payment.
- Continue using the existing payment method already on file.
- Retain the invoice for accounting and audit purposes.
- Follow normal finance approval procedures before authorizing payment.

**Email 10 Analysis- CONGRATULATIONS!!! YOU
HAVE WON USD 1,000,000 IN THE
INTERNATIONAL EMAIL LOTTERY**

Email Overview

Field	Finding
-------	---------

Subject	CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY
From	INTERNATIONAL LOTTERY BOARD (claims.department009@yandex-mailer.com)
Reply-To	agent.williams.claims@outlook-verify.info
Return-Path	claims.department009@yandex-mailer.com
Classification	Suspicious (Phishing / Advance Fee Fraud (Lottery Scam)
Received From	unknown-relay-node4.freehosting-mail.com (185.220.101.44, Netherlands)
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption	No
Attachment	hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921

OSINT Investigation

URL Analysis

Embedded URL

[hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921](http://claim-your-prize-now.lottery-verify.info/claim?ref=44921)

Findings

- Uses a suspicious domain (**lottery-verify.info**) instead of an official lottery organization.
- Domain attempts to appear legitimate using generic words such as *claim*, *prize*, and *verify*.
- No connection to any recognized lottery authority.
- The email requests the victim to submit personal information and pay a **USD 250 processing fee** before claiming the prize.

Problems 9 Errors 1 Warning 8 Passed	Blacklist 0 Errors 0 Warning 8 Passed	Mail Server 7 Errors 1 Warning 0 Passed	Web Server 1 Errors 0 Warning 0 Passed	DNS 1 Errors 0 Warning 0 Passed
--	---	---	--	---

10 Problems

Category	Host	Result	
http	outlook-verify.info	The remote name could not be resolved: 'outlook-verify.info' (http://outlook-verify.info)	More Info
mx	outlook-verify.info	DNS Record not found	More Info
mx	outlook-verify.info	[SUPPLEMENTAL]No DMARC Record found	More Info
mx	outlook-verify.info	[SUPPLEMENTAL]It is recommended to use a quarantine or reject policy. To enable BIMl, it is required to have one of these at 100%.	More Info
dns	outlook-verify.info	DNS Record not found	More Info
dmARC	outlook-verify.info	No DMARC Record found	More Info
spf	outlook-verify.info	No SPF Record found	More Info
spf	outlook-verify.info	[SUPPLEMENTAL]No DMARC Record found	More Info

Security Analysis

Multiple indicators clearly identify this email as an **Advance Fee Fraud (419 Scam)**:

- SPF, DKIM, and DMARC all failed.
- Email originated from an unknown free-hosting relay.
- No TLS encryption.
- Uses "undisclosed recipients" to send the same message to multiple victims.
- Claims the recipient won a lottery they never entered.
- Requests sensitive personal information.
- Demands an upfront processing fee before releasing the prize.
- Creates urgency by threatening forfeiture within 48 hours.

Indicators Observed

Malicious Indicators

- Fake lottery notification.
- Authentication failures (SPF, DKIM, DMARC).
- Suspicious Reply-To domain.
- Hosted on free mail infrastructure.
- Requests ID documents and personal information.
- Requests advance payment (USD 250).
- Uses urgency to pressure the victim.

- Suspicious embedded URL.

Risk Assessment

Category	Rating
Likelihood	High
Impact	High
Overall Risk	Critical

Recommendations

- Do **not** click the embedded link.
- Do **not** reply to the sender.
- Do **not** send identification documents or payment.
- Report the email to the Security Operations Center (SOC).
- Block the sender's email address and the associated domain.
- Educate users about lottery and advance-fee fraud scams.

Email 11 Quick Request Before My Flight

Email Overview

Field	Finding
Subject	Quick Request Before My Flight
From	Suresh Iyer (CFO) (suresh.iyer@solvexindustries.com)
Reply-To	s.iyer.cfo.travel@outlook.com
Return-Path	suresh.iyer@solvexindustries.com
Classification	Suspicious Business Email Compromise (BEC)
Received From	mail.solvexindustries.com (192.168.14.19) —

	header shows internal relay, but Reply-To routes externally
SPF	Pass (envelope sender matches solvexindustries.com)
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)

OSINT Investigation

Header Analysis

Unlike previous phishing emails, this email passes **SPF**, **DKIM**, and **DMARC** authentication and originates from the organization's internal mail server.

However, one critical indicator stands out:

- **Reply-To address:** s.iyer.cfo.travel@outlook.com

Although the sender appears to be the company's CFO, replies are redirected to a **personal Outlook account** instead of the official company domain.

This mismatch is a strong indicator of a **Business Email Compromise (BEC)** attempt.

OUTLOOK.COM Domain Health Report

Complete

Problems

- ✖ 4 Errors
- ⚠ 5 Warning
- ✔ 109 Passed

Blacklist

- ✖ 0 Errors
- ⚠ 0 Warning
- ✔ 75 Passed

Mail Server

- ✖ 3 Errors
- ⚠ 3 Warning
- ✔ 20 Passed

Web Server

- ✖ 1 Errors
- ⚠ 0 Warning
- ✔ 0 Passed

DNS

- ✖ 0 Errors
- ⚠ 2 Warning
- ✔ 14 Passed

9 Problems

Category	Host	Result	More Info
✖ dmarc	outlook.com	DMARC Quarantine/Reject policy not enabled	More Info
✖ spf	outlook.com	[SUPPLEMENTAL]It is recommended to use a quarantine or reject policy. To enable BIM, it is required to have one of these at 100%.	More Info
✖ http	outlook.com	The remote server returned an error: (417) Expectation Failed. (http://outlook.com)	More Info

Your IP is: 102.61.133.1 | [Contact](#) [Terms & Conditions](#) [Security](#) [API](#) [Privacy](#) Phone: (800)-892-8852 | © Copyright 2004-2020, MCToolBox, Inc. All rights reserved. US Patents 10829353 B2 & 11481738 B2

Security Analysis

Despite passing all authentication checks, the content of the email contains several red flags:

- Requests the purchase of **five Amazon gift cards worth ₹5,000 each**.
- Creates urgency by stating the CFO is boarding a flight and needs help within **20 minutes**.
- Instructs the recipient **not to call** the office or verify the request.
- Requests the gift card codes be sent by email.
- Uses authority (the CFO) to pressure the employee into acting quickly.

These are common characteristics of **CEO fraud**, a form of Business Email Compromise where attackers exploit trust rather than technical vulnerabilities.

Indicators Observed

Legitimate Indicators

- SPF passed.
- DKIM passed.
- DMARC passed.
- TLS 1.3 encryption enabled.
- Email originated from the organization's mail server.

Suspicious Indicators

- External Outlook **Reply-To** address.
- Urgent request for gift cards.
- Pressure to act within 20 minutes.
- Attempts to prevent independent verification ("Don't call the office").
- Uses executive authority to influence the recipient.

Risk Assessment

Category	Rating
Likelihood	High
Impact	High
Overall Risk	High

Recommendations

- Do **not** purchase gift cards based solely on email requests.
- Verify unusual financial requests directly with the executive using a trusted communication channel (phone call, Microsoft Teams, or in-person conversation).
- Treat any request to purchase gift cards as suspicious until independently confirmed.
- Report the email to the Security Operations Center (SOC).
- Review mailbox rules and account activity to determine whether the executive's account has been compromised.

Email 12 Mandatory Security Awareness Training – Due This Friday

Email Overview

Field	Finding
Subject	Mandatory Security Awareness Training – Due This Friday
From	Information Security Team – Solvex Industries (infosec@solvexindustries.com)
Reply-To	infosec@solvexindustries.com
Return-Path	infosec@solvexindustries.com
Classification	Safe
Received From	mail.solvexindustries.com (192.168.14.19)
SPF	Pass
DKIM	Pass
DMARC	Pass

Encryption	Yes (TLS 1.3)
------------	---------------

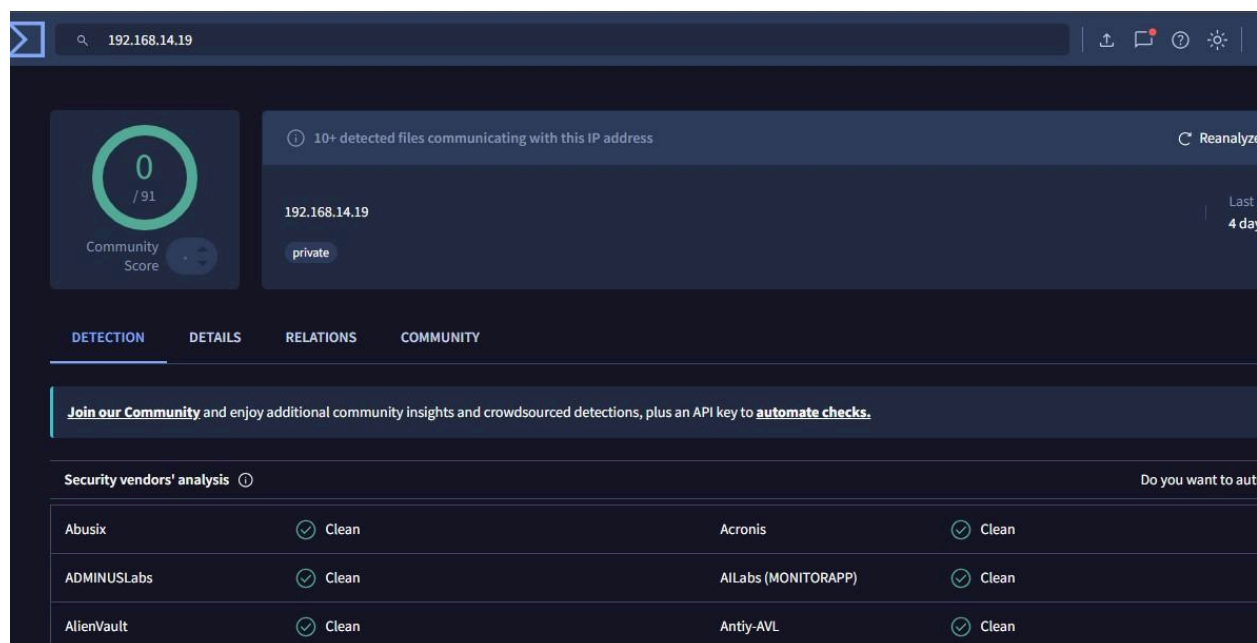
OSINT Investigation

Header Analysis

The email passed all authentication mechanisms:

- SPF – Pass
- DKIM – Pass
- DMARC – Pass
- TLS encryption enabled

The sender, Reply-To, and Return-Path all use the official **solvexindustries.com** domain, and the email originated from the organization's internal mail server.



Security Analysis

This email displays several characteristics of a legitimate internal corporate communication:

- Sent by the Information Security Team.
- Promotes cybersecurity awareness training.

- Does **not** request passwords, payment, or confidential information.
- Directs employees to use the company's internal learning portal.
- Advises users to contact the official IT Helpdesk if they experience issues.

Unlike phishing emails, there are no suspicious domains, urgent financial requests, or attempts to bypass security procedures.

Indicators Observed

Legitimate Indicators

- SPF, DKIM, and DMARC all passed.
- TLS encryption enabled.
- Internal company sender and mail server.
- Consistent sender, Reply-To, and Return-Path.
- References the organization's internal learning portal.
- Promotes cybersecurity best practices.

Suspicious Indicators

- None identified.

Risk Assessment

Category	Rating
Likelihood	low
Impact	low
Overall Risk	low

Email 13 Pending Invoice – Please Review & Process on Priority

Email Overview

Field	Finding
Subject	Pending Invoice – Please Review & Process on Priority
From	laccounts.receivable@shreeganesh-logistics.in
Reply-To	accounts.receivable@shreeganesh-logistics.in
Return-Path	mailer@shreeganesh-logistics.in
Classification	Suspicious (Phishing mail)
Received From	webmail-host-4.sharedhosting-cluster.com (41.203.88.17, unrelated hosting cluster)
SPF	Fail (domain not authorised to send)
DKIM	Fail
DMARC	Fail
Encryption	No
Attachment	Word Document (Macro-Enabled) • 1.1 MB

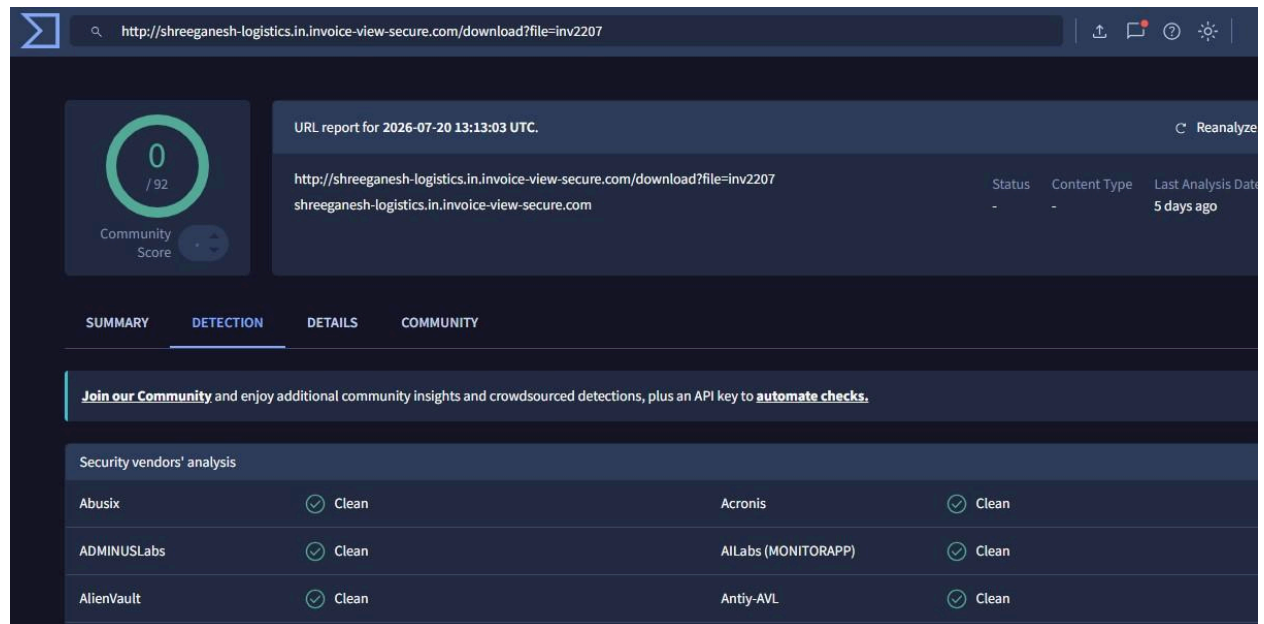
OSINT Investigation

Header Analysis

The email failed nearly every important authentication check:

- SPF failed.
- No DKIM signature.
- DMARC failed.
- No TLS encryption.

- Email originated from an unrelated shared hosting server rather than trusted corporate infrastructure.



Attachment Analysis

The attached file is a **macro-enabled Microsoft Word document (.docm)**.

The email explicitly instructs the recipient to:

"Please enable editing/macros if prompted..."

This is a major phishing indicator. Legitimate organizations rarely ask users to enable macros, while attackers commonly use malicious macros to download and execute malware.

URL Analysis

The embedded URL impersonates the logistics company by using a deceptive subdomain:

shreeganesh-logistics.in.invoice-view-secure.com

Security Analysis

This email combines several high-confidence phishing indicators:

- Failed SPF and DMARC authentication.

- Missing DKIM signature.
- No encrypted email transport.
- Macro-enabled Word attachment.
- Instructions to enable macros.
- Fake invoice used as a lure.
- Suspicious lookalike download URL.
- Financial urgency to encourage immediate action.

If the recipient enables macros, malicious code could execute automatically, leading to malware installation, credential theft, or remote access.

Indicators Observed

Malicious Indicators

- SPF failed.
- DKIM missing.
- DMARC failed.
- No TLS encryption.
- Macro-enabled **.docm** attachment.
- Explicit request to enable macros.
- Suspicious invoice-themed email.
- Lookalike download domain.
- Email sent from unrelated shared hosting infrastructure.

Risk Assessment

Category	Rating
Likelihood	High
Impact	Critical
Overall Risk	Critical

Recommendations

- Do **not** open the attachment.
- Do **not** enable Microsoft Office macros.

- Do **not** visit the embedded download link.
- Quarantine the email immediately.
- Block the sender's domain and the malicious URL.
- Scan the recipient's workstation if the attachment has already been opened.
- Educate users that invoice emails requesting macro activation are a common malware delivery technique.

Indicators of Compromise (IOCs)

IOC Type	Indicator	Associated Email	Threat
IP Address	45.137.22.9	Email 5	BEC / Wire Fraud
IP Address	185.220.101.44	Email 10	Lottery Scam
IP Address	41.203.88.17	Email 13	Malware Delivery
Domain	gmail-corpmail.com	Email 5	Fake Corporate Domain
Domain	microsoft-online.com	Email 7	Typosquatting
Domain	lottery-verify.info	Email 10	Phishing
Domain	invoice-view-secure.com	Email 13	Malware Distribution
Email Address	rajeev.malhotra.md@gmail-corpmail.com	Email 5	CEO Impersonation
Email Address	agent.williams.claims@outlook-verify.info	Email 10	Scam
Email Address	s.iyer.cfo.travel@outlook.com	Email 11	Suspicious Reply-To
URL	hxxp://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao	Email 7	Credential Harvesting
URL	hxxp://claim-your-prize-now.lottery-verify.info/	Email 10	Lottery Scam
URL	hxxp://shreeganeshtestistics.in.invoice-view-secure.com/download?fil	Email 13	Malware Download

	e=inv2207		
Attachment	Pending_Invoice_Challan_Details.docm	Email 13	Macro Malware
Attachment	JD_SeniorFinanceManager_Client.zip	Email 8	Suspicious ZIP Archive

Overall Recommendations

Based on the findings, the following security measures are recommended:

Email Security

- Enforce SPF, DKIM, and DMARC policies across all corporate domains.
- Configure the email gateway to quarantine messages that fail authentication.
- Block executable and macro-enabled attachments unless specifically required.

User Awareness

- Conduct regular phishing awareness training for all employees.
- Educate staff about CEO fraud, invoice scams, and business email compromise.
- Encourage employees to verify urgent financial requests through a secondary communication channel.

Endpoint Security

- Disable Microsoft Office macros by default.
- Deploy Endpoint Detection and Response (EDR) solutions.
- Ensure antivirus software and operating systems remain up to date.

Network Security

- Block access to known malicious domains and IP addresses.
- Use DNS filtering and secure web gateways to prevent access to phishing websites.
- Monitor outbound traffic for suspicious connections.

Incident Response

- Establish a clear process for reporting suspicious emails.
- Quarantine and investigate malicious emails promptly.

- Review email logs regularly for indicators of compromise.

Organizational Policies

- Require multi-person approval for high-value financial transactions.
- Implement multi-factor authentication (MFA) on all business email accounts.
- Perform periodic phishing simulations to assess employee readiness.

Conclusion

The email investigation identified a mixture of legitimate business communications and malicious emails targeting Solvex Industries through phishing, financial fraud, credential theft, and malware delivery techniques. While legitimate emails consistently passed authentication checks and originated from trusted infrastructure, malicious messages frequently exhibited authentication failures, suspicious domains, deceptive sender identities, macro-enabled attachments, or social engineering tactics designed to manipulate recipients.

A key finding of this investigation is that passing SPF, DKIM, and DMARC does not automatically guarantee an email is safe. The Business Email Compromise (BEC) example demonstrated that attackers can rely on psychological manipulation rather than technical deception, making human verification and security awareness equally important.

By implementing stronger email security controls, enforcing organizational security policies, and maintaining continuous user awareness training, Solvex Industries can significantly reduce the risk of phishing attacks, financial fraud, credential theft, and malware infections. This investigation reinforces the importance of combining technical controls with informed user behavior to build a resilient cybersecurity posture.

Final Classification Summary

Email	Classification	Risk Level
1	Safe	Low
2	Safe	Low
3	Business Email Compromise	High
4	Suspicious	Medium

5	Wire Transfer Fraud (BEC)	High
6	Safe	Low
7	Credential Phishing	High
8	Recruitment Scam	Medium
9	Safe	Low
10	Lottery Scam	High
11	CEO Fraud	High
12	Safe	Low
13	Malware Delivery	High